

Vertrag über die Verarbeitung personenbezogener Daten im Auftrag (Art. 28 DSGVO)

Stand: 2. August 2026. Dieses Dokument ist eine fachlich vollständige, technisch belastbare Vorlage: Alle Angaben zu Verarbeitungen, Systemen, Unterauftragnehmern, Regionen und Löschfristen entsprechen dem tatsächlichen Stand der Anwendung (geprüft gegen den Quellcode). Die **rechtliche** Formulierung muss vor der ersten Unterzeichnung von einer Anwältin bzw. einem Anwalt oder der/dem Datenschutzbeauftragten freigegeben werden. Ergänzend: „Verzeichnis der Verarbeitungstätigkeiten“, „Datenschutz-Folgenabschätzung“, „Sicherheitskonzept (TOM)“.

Zwischen

Auftraggeber (Verantwortlicher)

Firma: valuvita GmbH
Anschrift: Ute-Ruhnke-Str. 2, 67125 Dannstadt-Schauernheim
Register: Amtsgericht Ludwigshafen am Rhein, HRB 63660
Vertreten: Manfred Hoffmann und Dr. Christoph Wagner, Geschäftsführer
Kontakt: info@valuvita.de · +49 6231 94035-500
Datenschutzbeauftragte:r: _____

– nachfolgend „**Verantwortlicher**“ –

und

Auftragnehmerin (Auftragsverarbeiterin)

Lebenswerk.AI GmbH
Walter-Schneider-Straße 10
06317 Seegebiet Mansfelder Land
Geschäftsführer: Prof. Dr. med. Tobias D. Gantner
support@lebensgeschichten.ai

– nachfolgend „**Auftragnehmerin**“ –

§ 1 Gegenstand und Dauer

(1) Die Auftragnehmerin betreibt die Anwendung *Lebensgeschichten.ai*, mit der aus sprachgeführten Interviews persönliche Bücher, Gedenkbücher und Reden entstehen. Der Verantwortliche nutzt die Anwendung, um für die von ihm betreuten Personen Buchprojekte anzulegen, Zugänge auszugeben und die entstehenden Werke abzurufen.

(2) Gegenstand dieses Vertrages ist die Verarbeitung personenbezogener Daten durch die Auftragnehmerin im Auftrag und nach Weisung des Verantwortlichen.

(3) Der Vertrag beginnt mit Unterzeichnung und läuft, solange der Verantwortliche die Anwendung nutzt. Er endet mit Beendigung des zugrunde liegenden Hauptvertrages; § 10 (Rückgabe und Löschung) gilt darüber hinaus fort.

(4) Kündigung: Der Verantwortliche kann diesen Vertrag jederzeit außerordentlich kündigen, wenn die Auftragnehmerin gegen wesentliche Pflichten dieses Vertrages oder gegen die DSGVO verstößt.

§ 2 Art, Zweck und Umfang der Verarbeitung

(1) Zwecke

- Durchführung sprachgeführter Interviews (Fragen stellen, Vorlesen, Verschriftlichen des Gesprochenen),
- Erstellung der daraus abgeleiteten Werke: Buch, Gedenkbuch, Trauerrede, Anamnesebogen, Kapitelbilder, Stammbaum und Lebensposter,
- Bereitstellung der Werke als Word-Datei, Druck-PDF, E-Book und Umschlag,
- Versand notwendiger Nachrichten (Zugangs- und Wiederaufnahme-Links, Support),
- Betrieb, Fehlerbehebung und Sicherheit der Anwendung.

(2) Art der Verarbeitung: Erheben, Erfassen, Speichern, Organisieren, Verändern, Auslesen, Verwenden, Übermitteln an die in Anlage 2 genannten Unterauftragnehmer, Einschränken, Löschen und Vernichten.

(3) Kategorien betroffener Personen

Gruppe	Erläuterung
Erzählende Personen	Menschen, die ihre eigene Lebensgeschichte erzählen (Kategorie „Lebenswerk“)
Beitragende	Angehörige, Freundinnen, Weggefährten, die zu einem Gedenkbuch beitragen
Verstorbene	Personen, über die berichtet wird (nicht mehr von der DSGVO erfasst, aber schutzwürdig)
Dritte	Personen, die in Erzählungen beiläufig erwähnt werden
Beschäftigte des Verantwortlichen	Nutzerkonten für das Dashboard

(4) Kategorien personenbezogener Daten

Kategorie	Beispiele
Stammdaten	Name, Beziehung zur erzählten Person, Anrede, Geschlecht, E-Mail-Adresse

Kategorie	Beispiele
Inhaltsdaten	Sprachaufnahmen, deren Verschriftlichung, hochgeladene Fotos, erzeugte Texte und Bilder
Nutzungsdaten	Zeitstempel, Sitzungsfortschritt, Kostenerfassung je Projekt
Sicherheitsdaten	IP-basierte Zählstände zur Missbrauchsabwehr, Protokoll administrativer Vorgänge

(5) Besondere Kategorien (Art. 9 DSGVO). Die Anwendung fragt keine besonderen Kategorien ab. Da Menschen frei erzählen, **können** dennoch Angaben zu Gesundheit, Religion, Weltanschauung oder sexueller Orientierung fallen; in den Kategorien „Anamnese“ sind Gesundheitsdaten sogar der Zweck. Die Parteien behandeln solche Daten mit dem erhöhten Schutzniveau nach Art. 9 Abs. 2 lit. a DSGVO (ausdrückliche Einwilligung). Die Anwendung weist die KI an, nicht gezielt nach identifizierenden oder sensiblen Angaben **Dritter** zu fragen.

(6) Kein Training, keine Eigennutzung. Die Auftragnehmerin verwendet die Daten **nicht** zum Training, zur Verbesserung oder zur Evaluierung eigener oder fremder KI-Modelle. Sie hat dies mit ihren Unterauftragnehmern vertraglich abgesichert. Ebenso wenig nutzt sie die Daten für **eigene Zwecke, Forschung oder Auswertung**. Sollte eine wissenschaftliche Nutzung vorgesehen werden, setzt sie eine **gesonderte, ausdrückliche Einwilligung** der betroffenen Personen sowie eine Weisung des Verantwortlichen voraus; dieser Vertrag deckt sie nicht.

§ 3 Weisungsrecht

(1) Die Auftragnehmerin verarbeitet die Daten ausschließlich auf dokumentierte Weisung des Verantwortlichen. Als Weisung gelten dieser Vertrag, der Hauptvertrag und die Einstellungen, die der Verantwortliche im Dashboard vornimmt (etwa Aufbewahrungsfrist, aktivierte Funktionen, Sprache, Freigabe von Beiträgen).

(2) Mündliche Weisungen bestätigt der Verantwortliche unverzüglich in Textform.

(3) Hält die Auftragnehmerin eine Weisung für rechtswidrig, teilt sie dies unverzüglich mit und darf deren Ausführung bis zur Bestätigung aussetzen.

(4) Weisungsbefugte Personen benennen die Parteien in Anlage 3.

§ 4 Pflichten der Auftragnehmerin

1. **Vertraulichkeit:** Alle mit der Verarbeitung befassten Personen sind zur Vertraulichkeit verpflichtet (Art. 28 Abs. 3 lit. b, Art. 29 DSGVO) und in den Grundzügen des Datenschutzes unterwiesen.

1. **Sicherheit:** Die Auftragnehmerin trifft die in **Anlage 1** beschriebenen technischen und organisatorischen Maßnahmen nach Art. 32 DSGVO und erhält sie während der Vertragslaufzeit aufrecht.

1. **Unterstützung:** Sie unterstützt den Verantwortlichen bei Betroffenenrechten

(§ 5), bei der Meldung von Verletzungen (§ 6) sowie bei Datenschutz-Folgen- abschätzung und Konsultation der Aufsichtsbehörde (Art. 32–36 DSGVO).

1. **Ort der Verarbeitung:** Die Verarbeitung findet **ausschließlich in der Europäischen Union** statt. Eine Verlagerung in ein Drittland bedarf der vorherigen Zustimmung des Verantwortlichen und einer Grundlage nach Art. 44 ff. DSGVO.

1. **Datenschutzbeauftragte/r:** Die Auftragnehmerin benennt eine Kontaktstelle für Datenschutzfragen (Anlage 3) und teilt Änderungen unverzüglich mit.

1. **Trennung:** Daten verschiedener Verantwortlicher werden logisch getrennt verarbeitet; Zugriff besteht ausschließlich auf die eigenen Buchprojekte.

§ 5 Betroffenenrechte

(1) Wendet sich eine betroffene Person unmittelbar an die Auftragnehmerin, leitet diese das Anliegen unverzüglich an den Verantwortlichen weiter und beantwortet es nicht selbst — es sei denn, der Verantwortliche weist sie dazu an.

(2) Die Anwendung unterstützt die Rechte technisch:

Recht	Umsetzung in der Anwendung
Auskunft und Datenübertragbarkeit (Art. 15, 20)	Beitragende erhalten ihre Daten als PDF-Datenauskunft
Berichtigung (Art. 16)	Verschriftlichung und Buchtexte sind im Dashboard bearbeitbar
Löschung (Art. 17)	Einzelner Beitrag oder ganzes Projekt löschar; erfasst auch Bilder und Uploads
Einschränkung (Art. 18)	Projekt kann geschlossen und von der weiteren Verarbeitung ausgenommen werden
Widerruf der Einwilligung	jederzeit für die Zukunft; führt zur Löschung des Beitrags

(3) Die Auftragnehmerin unterstützt bei darüber hinausgehenden Anliegen im erforderlichen Umfang.

§ 6 Verletzung des Schutzes personenbezogener Daten

(1) Die Auftragnehmerin informiert den Verantwortlichen **unverzüglich, spätestens innerhalb von 24 Stunden** nach Kenntnis, über jede Verletzung des Schutzes personenbezogener Daten, die die im Auftrag verarbeiteten Daten betrifft.

(2) Die Meldung enthält, soweit bekannt: Art der Verletzung, betroffene Kategorien und ungefähre Zahl betroffener Personen und Datensätze, wahrscheinliche Folgen sowie ergriffene und vorgeschlagene Maßnahmen.

(3) Die Auftragnehmerin trifft unverzüglich Maßnahmen zur Eindämmung und dokumentiert den Vorfall nachvollziehbar.

(4) Meldungen an die Aufsichtsbehörde (Art. 33) und an betroffene Personen (Art. 34) obliegen dem Verantwortlichen.

§ 7 Unterauftragsverhältnisse

(1) Der Verantwortliche stimmt dem Einsatz der in **Anlage 2** genannten Unterauftragnehmer zu (allgemeine schriftliche Genehmigung, Art. 28 Abs. 2 Satz 2).

(2) Beabsichtigt die Auftragnehmerin, einen weiteren Unterauftragnehmer hinzuzuziehen oder zu ersetzen, teilt sie dies **mindestens 30 Tage vorher** in Textform mit. Der Verantwortliche kann binnen 14 Tagen aus wichtigem, datenschutz- rechtlichem Grund widersprechen. Kommt keine Einigung zustande, darf der Verantwortliche den Hauptvertrag außerordentlich kündigen.

(3) Die Auftragnehmerin verpflichtet jeden Unterauftragnehmer auf ein Schutzniveau, das diesem Vertrag entspricht, und haftet für dessen Verhalten wie für eigenes.

(4) Keine Unterauftragsverarbeitung sind Nebenleistungen ohne Zugriff auf die Daten (etwa Telekommunikation oder Reinigung).

§ 8 Kontrollrechte

(1) Der Verantwortliche hat das Recht, die Einhaltung dieses Vertrages zu überprüfen — durch Auskunft, Vorlage von Nachweisen oder, nach Ankündigung mit angemessener Frist, durch Kontrolle vor Ort während der Geschäftszeiten und ohne Störung des Betriebsablaufs.

(2) Die Auftragnehmerin weist die Einhaltung vorrangig durch aktuelle Unterlagen nach: dieses Dokument samt Anlagen, „Sicherheitskonzept (TOM)“, „Verzeichnis der Verarbeitungstätigkeiten“, „Datenschutz-Folgenabschätzung“ sowie die Zertifikate und Prüfberichte ihrer Unterauftragnehmer (ISO 27001, SOC 2 der Microsoft-Rechenzentren).

(3) Für Kontrollen, die über eine jährliche hinausgehen und nicht durch einen konkreten Anlass veranlasst sind, kann die Auftragnehmerin eine angemessene Aufwandsentschädigung verlangen.

§ 9 Haftung

Es gilt Art. 82 DSGVO. Im Innenverhältnis stellen sich die Parteien nach dem Anteil ihres jeweiligen Verschuldens frei. Haftungsbeschränkungen des Hauptvertrages bleiben unberührt, soweit sie Ansprüche

betroffener Personen nach Art. 82 DSGVO nicht beschränken.

§ 10 Rückgabe und Löschung nach Vertragsende

- (1) Nach Abschluss der Leistungen löscht die Auftragnehmerin alle im Auftrag verarbeiteten Daten oder gibt sie zurück — nach Wahl des Verantwortlichen.
- (2) Der Verantwortliche teilt seine Wahl spätestens 30 Tage vor Vertragsende in Textform mit. Ohne Mitteilung wird gelöscht.
- (3) **Unabhängig davon** löscht die Anwendung Rohdaten bereits im laufenden Betrieb automatisch nach der eingestellten Aufbewahrungsfrist (Standard 90 Tage nach dem Anlass, für Anamnese-Projekte 14 Tage). Erfasst sind Beiträge, Aufnahmen, Verschriftlichungen und hochgeladene Fotos.
- (4) Fertiggestellte Werke (Buchtexte, gesetzte Bildseiten) bleiben bis zur Löschung des Projekts erhalten — sie sind das Ergebnis, das der Verantwortliche beauftragt hat.
- (5) Die Löschung wird auf Verlangen in Textform bestätigt. Gesetzliche Aufbewahrungspflichten bleiben unberührt; betroffene Daten werden bis zum Ablauf in der Verarbeitung eingeschränkt.

§ 11 Schlussbestimmungen

- (1) Änderungen bedürfen der Textform.
- (2) Sollte eine Bestimmung unwirksam sein, bleibt der übrige Vertrag wirksam.
- (3) Bei Widersprüchen gilt: dieser Vertrag vor dem Hauptvertrag, soweit es den Datenschutz betrifft.
- (4) Es gilt deutsches Recht.

Ort, Datum: _____

Ort, Datum: _____

Dr. Christoph Wagner
valuvida GmbH

Prof. Dr. med. Tobias D. Gantner
Lebenswerk.AI GmbH

Anlage 1 — Technische und organisatorische Maßnahmen (Art. 32 DSGVO)

Ausführlich in „Sicherheitskonzept (TOM)“. Kurzfassung:

Vertraulichkeit

- Zutritt: keine eigenen Server; Betrieb ausschließlich in Microsoft-Azure-Rechenzentren in der EU (zertifiziert nach ISO 27001, SOC 2).

- Zugang: Konten je Person, Passwortrichtlinie, kein Standardpasswort; Sitzungen über HMAC-signierte Token mit 12 Stunden Gültigkeit; Sperren gegen Erraten von Passwörtern.

- Zugriff: rollengetrennt (Administration, Manager, Endnutzer, Beitragende). Manager

sehen ausschließlich ihre eigenen Projekte; fremde Projekte werden nicht als „gesperrt“, sondern als „nicht vorhanden“ beantwortet, damit sich Zugangscode nicht durchprobieren lassen. Zugangscode bestehen aus zehn Zeichen eines verwechslungs-freien Alphabets (rund 10^{15} Möglichkeiten) und werden zusätzlich ratenbegrenzt.

- Trennung: eigene Datenbankzeile je Projekt, Bilder in projekteigenen Ordnern;

Lesezugriffe auf Bilder nur über kurzlebige, signierte Links (1 Stunde).

Integrität

- Weitergabe: TLS auf allen Verbindungen; Speicherung verschlüsselt (AES-256).

- Eingabe: dauerhaftes Protokoll administrativer Vorgänge (wer, wann, was).

Verfügbarkeit und Belastbarkeit

- Verwalteter Datenbankdienst mit automatischer Sicherung und Wiederherstellungspunkt;

Container-Betrieb mit automatischem Neustart; Geheimnisse nur serverseitig.

Verfahren zur Überprüfung

- Jährliche Prüfung dieses Dokuments und der Dienstleisterlage („Betriebs-Runbook Datenschutz“);

Datenschutz-Folgenabschätzung in „Datenschutz-Folgenabschätzung“.

Datenminimierung als Voreinstellung

- Rohdaten werden automatisch nach Frist gelöscht; Bilder und Uploads eines Projekts

liegen in einem gemeinsamen Ordner, damit eine Löschung nichts übersieht; die KI ist angewiesen, nicht nach sensiblen Angaben Dritter zu fragen.

Anlage 2 — Genehmigte Unterauftragnehmer

Stand 1. August 2026. Sämtliche Verarbeitung findet in der EU statt; es besteht **keine Drittlandübermittlung**.

Unterauftragnehmer	Leistung	Region	Grundlage
Microsoft Ireland Operations Ltd. — Azure OpenAI (gpt-4.1)	Interviewführung, Erstellung von Buch- und Redetexten	EU	Microsoft DPA
Microsoft — Azure AI Speech	Vorlesen (TTS) und Spracherkennung (STT)	westeuropa	Microsoft DPA
Microsoft — Azure AI Speech „Voice Live“	Live-Sprachgespräch; nur wenn ausdrücklich freigeschaltet , Voreinstellung aus	swedencentral	Microsoft DPA
Microsoft — Azure AI Foundry (FLUX.2 [pro])	Erzeugung der Kapitel- und Coverbilder	EU	Microsoft DPA
Microsoft — Azure Database for PostgreSQL	Speicherung aller Projektdaten	North Europe	Microsoft DPA
Microsoft — Azure Blob Storage	Bilder, hochgeladene Fotos, abgelegte PDFs	EU	Microsoft DPA
Microsoft — Azure Container Apps	Betrieb der Anwendung und der Aufräum-Aufträge	EU	Microsoft DPA
Microsoft — Microsoft 365 / Graph	Versand von Zugangs-, Wiederaufnahme- und Support-Nachrichten	EU	Microsoft DPA

Modellanbieter Black Forest Labs (FLUX) erhält keine Daten; das Modell läuft innerhalb von Azure.

Keine weiteren Empfänger. Insbesondere werden keine Analyse-, Tracking- oder Schriftarten-Dienste Dritter eingebunden; QR-Codes werden seit dem 1. August 2026 im Browser erzeugt statt bei einem externen Dienst.

Anlage 3 — Ansprechpartner

Rolle	Verantwortlicher	Auftragnehmerin
Weisungsbefugt	_____	Prof. Dr. med. Tobias D. Gantner
Datenschutz-Kontakt	_____	Florian Burg, Projektleiter · florian.burg@lebensgeschichten.ai
Meldung von Vorfällen	_____	support@lebensgeschichten.ai